



Cybersecurity Governance Guide for Regulated Organizations

Securities and Exchange Commission (SEC)

Technical controls, regulatory frameworks, and continuous monitoring for cybersecurity governance under SEC requirements.

1. SEC Cybersecurity Regulatory Landscape

SEC cybersecurity requirements have expanded significantly. Investment advisers and broker-dealers face overlapping obligations:

- Regulation S-P (amended 2024): Requires written policies to safeguard customer information. Incident notification to affected customers within 30 days of discovering a breach.
- Regulation S-ID: Identity theft red flags program required for broker-dealers and investment companies.
- Cybersecurity Risk Management Rules (2023): Public companies must disclose material cybersecurity incidents within 4 business days on Form 8-K and disclose risk management processes annually on Form 10-K.
- Proposed Investment Adviser Cybersecurity Rule: Would require written cybersecurity policies, annual risk assessments, incident reporting to SEC, and recordkeeping of cybersecurity events.
- SEC Enforcement: The SEC has brought enforcement actions for inadequate cybersecurity policies, failure to disclose breaches, and misrepresentation of security controls.

2. Required Technical Controls Under SEC

SEC examiners evaluate whether cybersecurity policies are technically enforced. These controls must be documented and evidenced:

- ✓ Encryption of customer data at rest and in transit. Reg S-P requires safeguarding of customer records.
- ✓ MFA on all systems handling customer data, financial records, and trading systems.
- ✓ EDR/XDR on all endpoints with active monitoring and documented alert disposition.
- ✓ Network segmentation isolating trading systems and customer data environments.
- ✓ Access controls with quarterly reviews documented with evidence of review completion.
- ✓ Patch management with documented SLAs: critical patches within 72 hours, high within 30 days.

3. Incident Response Under SEC Requirements

SEC incident response obligations are time-critical. Your IRP must be calibrated to meet these timelines:

- Materiality Determination: Public companies must determine whether a cybersecurity incident is material. This determination must be made promptly and documented.

- Form 8-K Disclosure: Material incidents must be disclosed within 4 business days of determining materiality.
- Reg S-P Customer Notification: Notify affected customers within 30 days of discovering unauthorized access to their information.
- Exam Documentation: Maintain incident logs with timeline, containment steps, root cause, and remediation. Examiners will request this on Day 1 of a cybersecurity-focused examination.
- Tabletop Exercises: Annual tabletop exercises specifically testing SEC notification timelines and materiality determination procedures.

4. Vendor and Third-Party Risk Under SEC

SEC-regulated firms are responsible for cybersecurity failures at vendors that handle customer data:

- Vendor Inventory: Maintain a current inventory of all third parties with access to customer data or firm systems.
- Due Diligence: Require SOC 2 Type II annually for critical vendors. Security questionnaire before onboarding.
- Contractual Requirements: Data security obligations, breach notification within 24-48 hours, right to audit, and data return or destruction on termination.
- Ongoing Monitoring: Annual review of critical vendor security posture.
- Reg S-P Scope: Vendor access to customer records creates Reg S-P obligations. Your safeguard program must extend to cover vendor access.

5. Examination Documentation Requirements

SEC cybersecurity examinations require production of specific documentation. Maintain examination-ready files for:

- Written cybersecurity policies and procedures: current, dated, and board or senior management approved.
- Most recent risk assessment results with identified gaps and remediation status.
- Evidence of technical control implementation: configuration screenshots, MDM compliance reports, patch status reports.
- Incident log for the past 3 years for all incidents regardless of severity.
- Vendor due diligence files: SOC 2 reports, questionnaires, and contracts with security provisions.

- Training records: completion logs with dates and topics, phishing simulation results.

6. SEC Cybersecurity Exam Readiness Checklist

Before an SEC examination, confirm you can produce within 24 hours:

- Written cybersecurity policies signed by senior management dated within last 12 months
- Most recent cybersecurity risk assessment with remediation roadmap
- Evidence of technical controls: MFA reports, encryption configs, patch status
- Incident log for prior 3 years with timelines and remediation steps
- Vendor inventory with due diligence documentation
- Network diagram showing segmentation of customer data environments
- Access review records for systems handling customer data
- Annual penetration test or vulnerability assessment results

NEXT STEP

Build Your Governance Roadmap

Reading this guide is step one. Step two is knowing exactly where your organization stands and what it takes to close the gaps before a regulator does it for you.

Our assessment delivers a prioritized governance roadmap tailored to your regulatory environment.

WHAT THE ASSESSMENT DELIVERS

- ✓ AI usage discovery across your organization
- ✓ Governance gap analysis by regulatory framework
- ✓ Infrastructure and vendor AI risk review
- ✓ Regulatory exposure analysis (SEC, FINRA, HIPAA)
- ✓ Prioritized governance roadmap
- ✓ Board-ready executive summary
- ✓ Regulatory readiness score by framework

Book Your Assessment →

centience.ai/assessments/financial-services

Call us: (877) 945-7177